

● IBM BOB 2.0 HACKATHON

RepoWatch

An AI-native engineering governance auditor

Triaxis Ventures

The problem

AI coding agents make shipping cheap. They don't make it cheap to notice when velocity has outrun governance.

- Vulnerabilities nobody's tracking
- Code deployed with no tests behind it
- PRs stale, or merged through unresolved conflicts
- Secrets/PII slipped into a public repo
- AI-authored decisions rubber-stamped with no human call

The approach: two tiers

TIER 1 — DETERMINISTIC (runs in minutes)

Dependabot vulnerabilities · stale PRs · unresolved-conflict merges · untested deploys · PII scan · repo sprawl

TIER 2 — JUDGMENT-BASED (IBM Bob 2.0, Agent mode)

Plan-before-ship detection · spaghetti/inflated-diff analysis · HITL-outsourcing detection

Some questions need a regex. Some need actual reasoning over real content.

Real results, not a demo dataset

Dogfooded against our own 14-repo GitHub org.

13/14

repos with zero vulnerability scanning enabled — not clean, just never turned on

28

open Dependabot alerts on the flagship repo, previously untracked

11 / 1 / 14

PRs open >10 days / unresolved-conflict merge / deploys with no test run

Where Bob did the real work

- Read actual commit/diff content (`git log` , `git diff` , `git show`) — not just PR titles
- Checked for duplicate logic (`grep` , `glob`) before calling anything spaghetti
- Read governance docs to learn the *stated* HITL policy before judging PRs against it
- **Found no classical spaghetti** — reported that honestly instead of manufacturing findings
- Caught real, specific issues instead: tests that assert on source text, 390 undisclosed lockfile lines, a major dependency bump merged with no review

Every "human-reviewed decision" verdict in our own audit rests on **the AI's own written account** of what a human decided — not an independently verifiable record.

A governance tool built to catch AI decisions shipped without human oversight has to hold *itself* to that same standard. RepoWatch does — instead of claiming more certainty than the evidence supports.

Try it

```
pip install -e .  
repowatch <your-github-org>
```

Live demo: axxess-triaxis.github.io/RepoWatch

Source: github.com/axxess-triaxis/RepoWatch

MIT licensed.